MBA · 재직자 강의

개인정보보호 머신러닝(PPML)

연합학습 · 차등 프라이버시 · 동형암호 · 다자간 연산

Privacy-Preserving Machine Learning — 원리, 사례, 규제

데이터를 모으지 않고, 보지 않고, 기억하지 않게 학습하는 방법을 다룬다.
기술의 작동 원리와 국내외 실제 운영 사례, 2026년 한국·EU 규제 변화를 한 흐름으로 정리한다.

이 강의는 세 가지 메시지로 요약된다

기술 이름보다 먼저 기억할 판단 기준이다

1

이름을 지워도 사람은 드러난다

몇 개의 단서와 다른 데이터의 연결, 모델의 기억이 개인을 다시 찾아낸다.

2

PPML은 단일 기술이 아니라 조합이다

연합학습으로 데이터를 묶어 두고, DP로 기억을 제한하고, 암호로 연산을 숨긴다.

3

규제는 금지에서 증명으로 바뀌었다

한국 AI 특례와 EU 디지털 옴니버스 모두 안전장치를 증명하면 쓰도록 길을 열었다.

질문은 하나다 — 이 데이터로 학습해도 특정 개인이 드러나지 않는다고 어떻게 보장할 것인가

머신러닝과 개인정보 보호는 구조적으로 충돌한다

데이터를 많이 모을수록 모델은 좋아지고 위험도 커진다

좋은 모델에는 많은 데이터가 필요하지만, 그 데이터는 여러 기관과 기기에 흩어져 있고 민감하다

모으기 어려운 두 가지 이유

- 비용: 수백만 대 기기의 데이터를 서버로 보내는 통신·저장 비용이 크다
- 규제: 의료·금융·위치 정보는 개인정보보호법과 GDPR이 이동을 제한한다

이름만 지우면 될까

- 가명처리만으로는 다른 정보와 결합해 다시 식별될 수 있다
- 우편번호·생년월일·성별 세 칸만으로 미국인 87%가 특정된다 (PART 1)
- 그래서 미 인구조사국은 2020년 센서스에 DP를 도입했다

PPML 논의는 다섯 개 용어로 시작한다

국내 법령 용어와 기술 용어를 함께 정리한다

용어	뜻	예
개인정보	살아 있는 개인을 알아볼 수 있는 정보	이름, 계좌번호, 얼굴 영상
가명정보	추가 정보 없이는 누구인지 알 수 없게 처리한 정보	고객번호를 일련번호로 대체
익명정보	어떤 수단으로도 다시 식별할 수 없는 정보	충분히 집계된 통계
PET	개인정보 보호 강화 기술(Privacy Enhancing Tech.)	합성데이터, DP, 동형암호
PPML	PET를 학습·추론 과정에 적용한 머신러닝	연합학습 + DP 키보드 모델

가명정보는 여전히 개인정보다. 익명정보가 되어야 개인정보보호법 적용에서 벗어난다

01

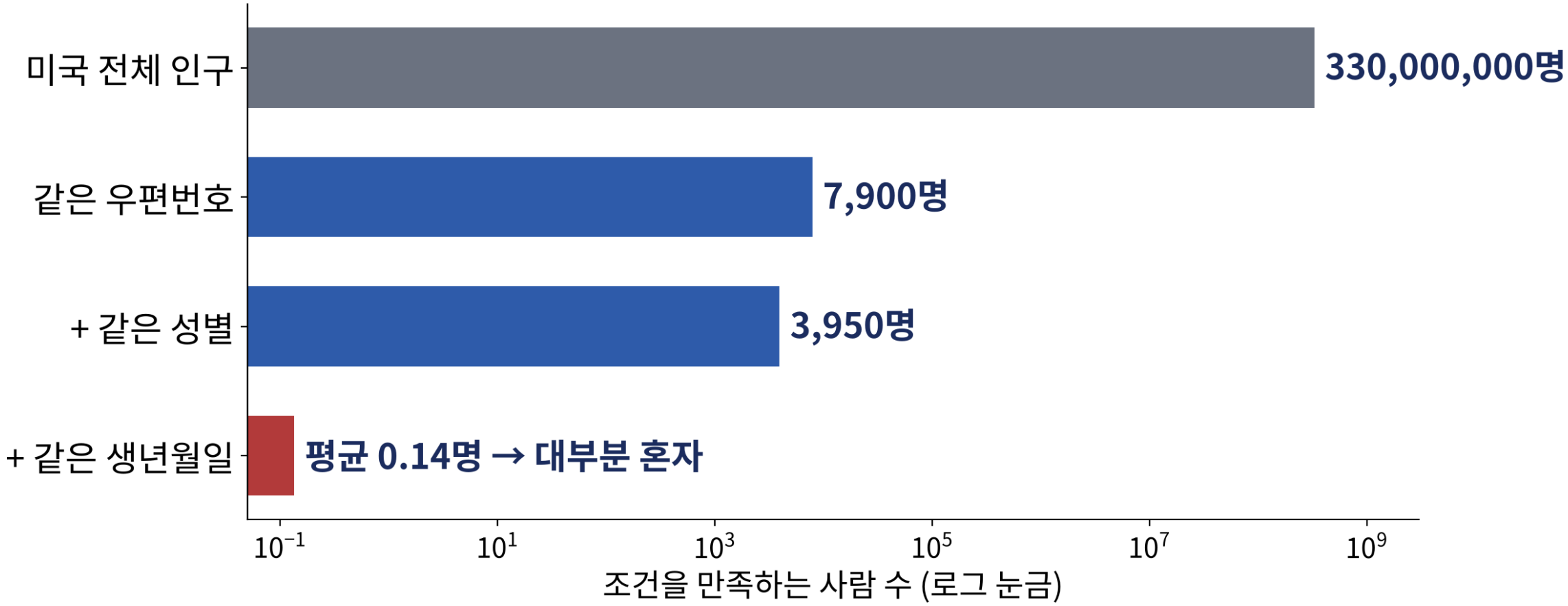
PART 1 · 재식별

몇 개의 단서면 누구인지 알 수 있다

이름을 지운 데이터도 다른 데이터와 만나면 다시 사람이 된다

세 칸만 남겨도 대부분은 혼자다

Sweeney(2000): 우편번호·생년월일·성별로 미국인의 87%가 한 사람으로 특정된다



칸의 수가 사람 수보다 많으면 거의 모두 혼자가 된다

가정: 생일이 80년에 고르게 퍼져 있다. 한국 수치는 행정구역 평균 인구로 한 근사 계산이다

$$\Pr[\text{혼자}] \approx e^{-N/K}, \qquad N = \text{같은 지역 인구}, \quad K = \underbrace{365 \times 80}_{\text{생년월일}} \times \underbrace{2}_{\text{성별}} = 58{,}400$$

87%

미국 · 우편번호 평균 7,900명
Sweeney의 실측치와 일치

약 78%

한국 · 읍면동 평균 약 1.5만 명
(인구 5,170만 ÷ 약 3,500개)

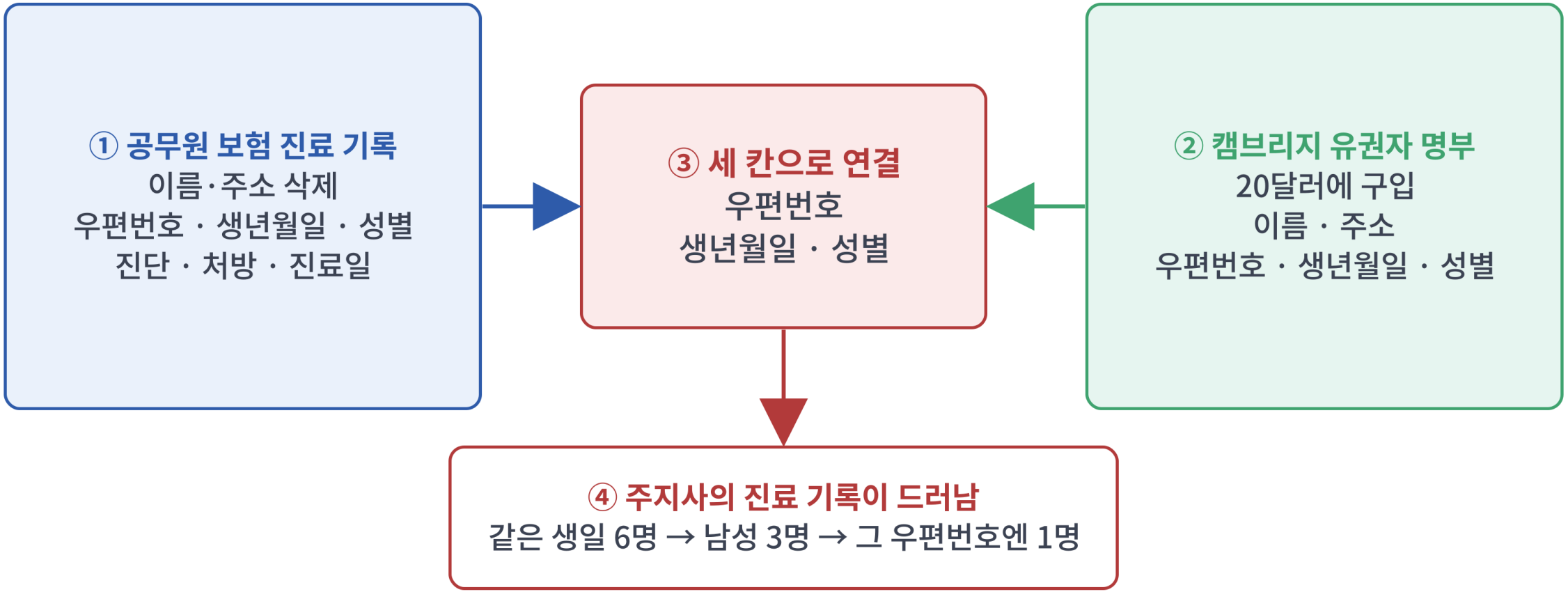
약 2%

한국 · 시군구 평균 약 23만 명
지역을 넓히면 급격히 안전해진다

그래서 가명처리에서는 주소를 시군구 수준으로, 생년월일을 출생연도나 연령대로 줄이는 방식을 흔히 쓴다

이름을 지운 진료 기록은 20달러짜리 유권자 명부로 다시 열렸다

1997년 매사추세츠 공무원 보험(GIC) 자료 — 공통 칸으로 두 데이터를 잇는 연결 공격(linkage attack)

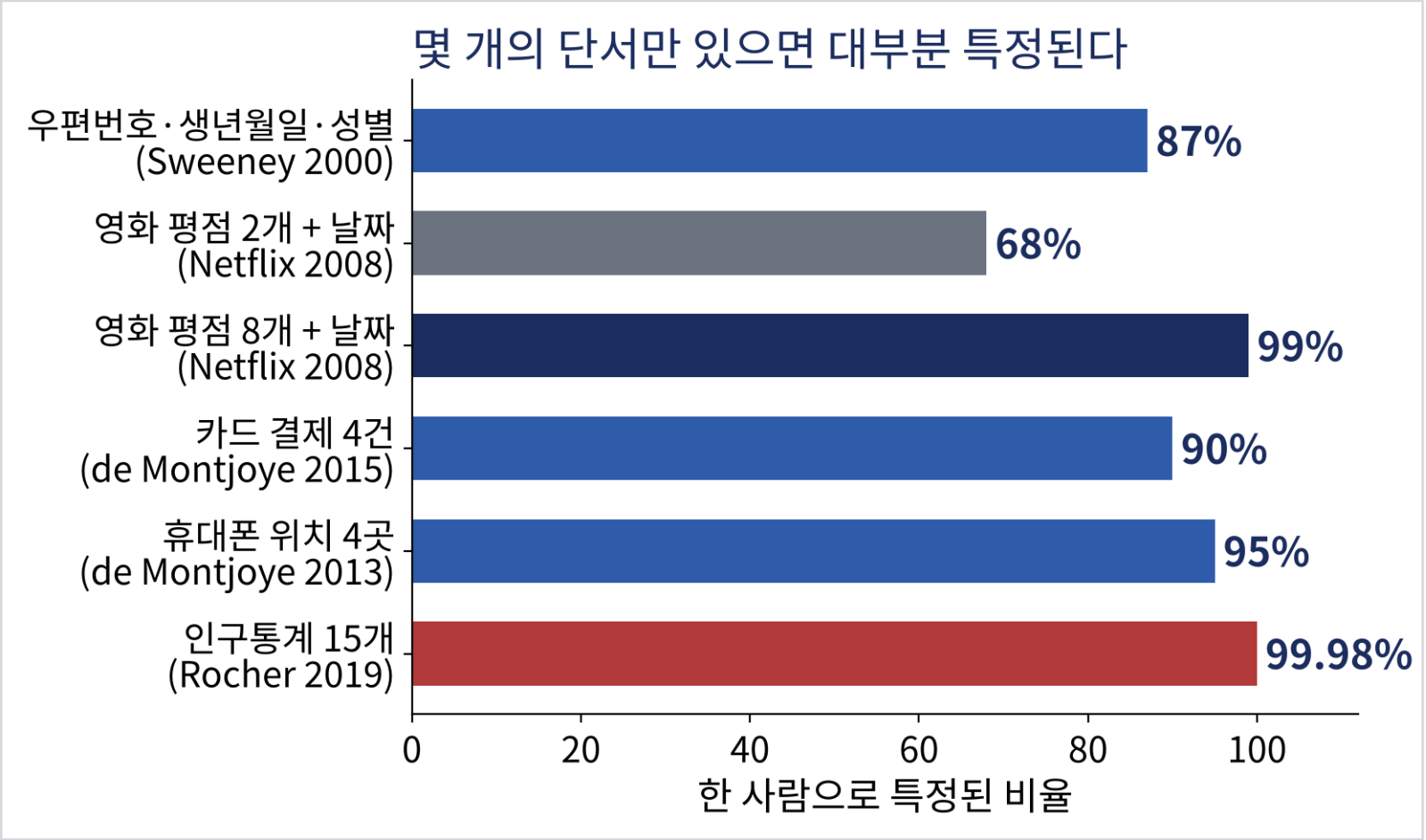


단서 네 개 안팎이면 거의 모두 특정된다

평점·결제·위치처럼 희소한 행동 기록은 사람마다 지문처럼 다르다

읽는 법

- 언제·어디서가 지문
- 희소할수록 위험
- 단서는 쉽게 구한다



익명으로 공개한 데이터가 실명으로 돌아온 네 사건

모두 이름과 번호를 지우거나 바꿔서 공개한 데이터였다

AOL 검색 기록 (2006)

- 65만 명의 검색어 약 2천만 건을 번호만 붙여 공개했다
- 뉴욕타임스가 이용자 4417749번을 62세 여성으로 찾아냈다

넷플릭스 평점 (2006~2010)

- 50만 명의 영화 평점을 IMDb 공개 평점과 대조해 식별했다
- 소송 끝에 2010년 2차 경진대회를 취소했다

뉴욕 택시 (2014)

- 1억 7,300만 건의 택시 번호 해시를 모든 번호를 넣어 한 시간 만에 풀었다
- 연예인 승차 사진과 시각·장소를 맞춰 행선지와 요금이 드러났다

스트라바 운동 지도 (2018)

- 이용자들의 달리기 경로를 모은 전 세계 히트맵을 공개했다
- 해외 군사기지의 윤곽과 순찰 경로가 그대로 보였다

k-익명성은 누구든 최소 k명 속에 숨게 만든다

Sweeney(2002). 나이·주소 같은 준식별자를 뭉뚱그려(일반화) 같은 값을 공유하게 한다

$$\min_{q} \left| \{ i \ : \ \text{준식별자}_i = q \} \right| \ \geq \ k \qquad (\text{모든 조합이 최소 } k\text{명})$$

원본 (이름만 삭제)

나이	동	성별	연체
34	역삼1동	남	정상
36	역삼2동	남	정상
52	대치1동	여	연체
57	대치4동	여	연체

일반화 후 (k = 2)

나이대	지역	성별	연체
30대	역삼	남	정상
30대	역삼	남	정상
50대	대치	여	연체
50대	대치	여	연체

누구도 한 명으로 특정되지 않지만, 50대 대치동 여성이라면 연체 사실은 그대로 드러난다

익명인지는 데이터만 보고 판정할 수 없다

k-익명성의 한계가 차등 프라이버시(PART 3)로 이어진다

익명성은 데이터의 성질이 아니라 공격자가 가진 다른 데이터와의 관계로 정해진다

k-익명성이 못 막는 것

- 동질성 공격: 같은 그룹이 모두 연체면 연체 사실이 드러난다
- 배경지식 공격: 공격자가 새 데이터를 구하면 기준이 무너진다

그래서 바뀐 접근

- 법은 가명정보도 개인정보로 보고 결합·반출을 통제한다
- DP는 공격자가 무엇을 알든 성립하는 보장을 준다

학습된 모델은 네 가지 경로로 개인정보를 흘린다

공격자가 접근하는 대상에 따라 공격 유형이 나뉜다

공격	공격자가 보는 것	새어 나가는 것
멤버십 추론	모델의 출력 확률	특정인이 학습 데이터에 있었는지 여부
모델 인버전	모델 출력과 일부 속성	학습에 쓰인 개인의 민감 속성
그래디언트 역추론	연합학습에서 전송된 기울기	학습 입력 이미지·문장 자체
학습 데이터 추출	생성 모델의 응답	학습 문서의 원문 그대로

앞의 둘은 고전적 분류 모델, 뒤의 둘은 연합학습과 생성형 AI에서 새로 커진 위험이다

정렬된 상용 챗봇도 학습 원문을 토해낼 수 있다

Nasr 외(ICLR 2025): 오픈·준공개·상용 모델 대상 추출 실험

GB 단위

Pythia·GPT-Neo 등 공개 모델에서
추출한 학습 데이터 양

150배

발산(divergence) 공격 때 ChatGPT
가
학습 데이터를 내놓는 속도 증가

수천 건

정렬(alignment)을 무력화해
복원한 상용 모델 학습 예시

읽는 법

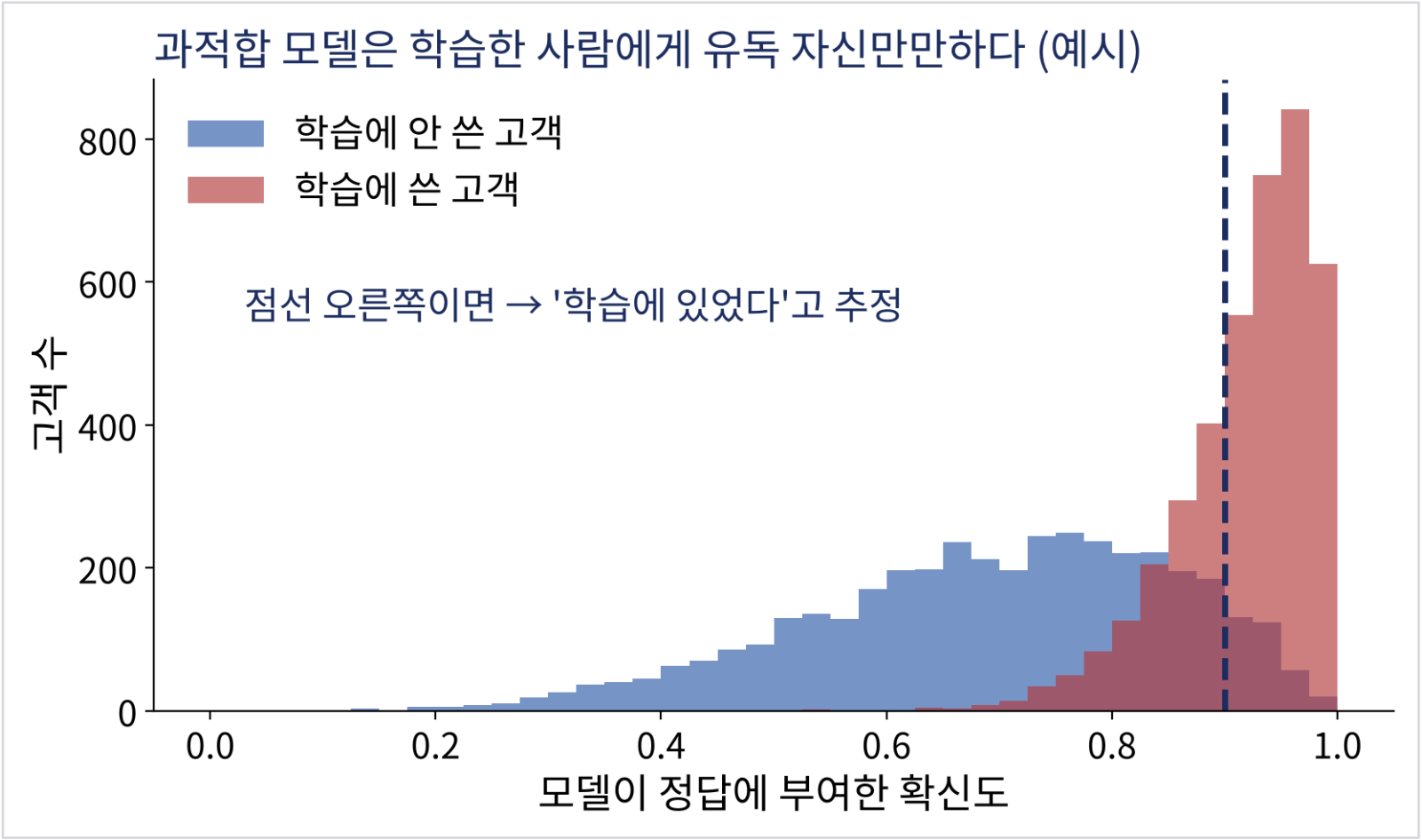
- 큰 모델일수록 더 많이 기억한다. 정렬은 기억을 지우지 못하고 가릴 뿐이다
- 그래서 개인정보가 섞인 데이터로 LLM을 학습할 때는 학습 단계의 보호가 필요하다

과적합 모델은 학습에 쓴 사람을 티 나게 알아본다

멤버십 추론 공격(Shokri 외 2017)의 원리를 보여 주는 예시 분포

읽는 법

- 학습 고객: 확신 높음
- 새 고객: 넓게 퍼짐
- 이 차이가 새는 정보



PPML 기술은 ML 생애주기 네 단계에 나뉘어 배치된다

이 강의는 학습(②)과 연산(③)을 중심으로, 앞뒤 단계를 함께 다룬다



02

PART 2 · 연합학습

연합학습 (Federated Learning)

데이터는 제자리에 두고 학습 결과만 주고받는다

연합학습은 데이터 대신 학습 결과를 모은다

McMahan 외(2017) FedAvg — 오늘날 가장 널리 쓰이는 기본 알고리즘

$$w_{\text{전역}}^{t+1} = \sum_{k=1}^{K} \underbrace{\frac{n_k}{n}}_{\text{기관 } k\text{의 데이터 비중}} \underbrace{w_k^{t+1}}_{\text{기관 } k\text{가 학습한 가중치}}$$

비유: 학교 간 공부 모임

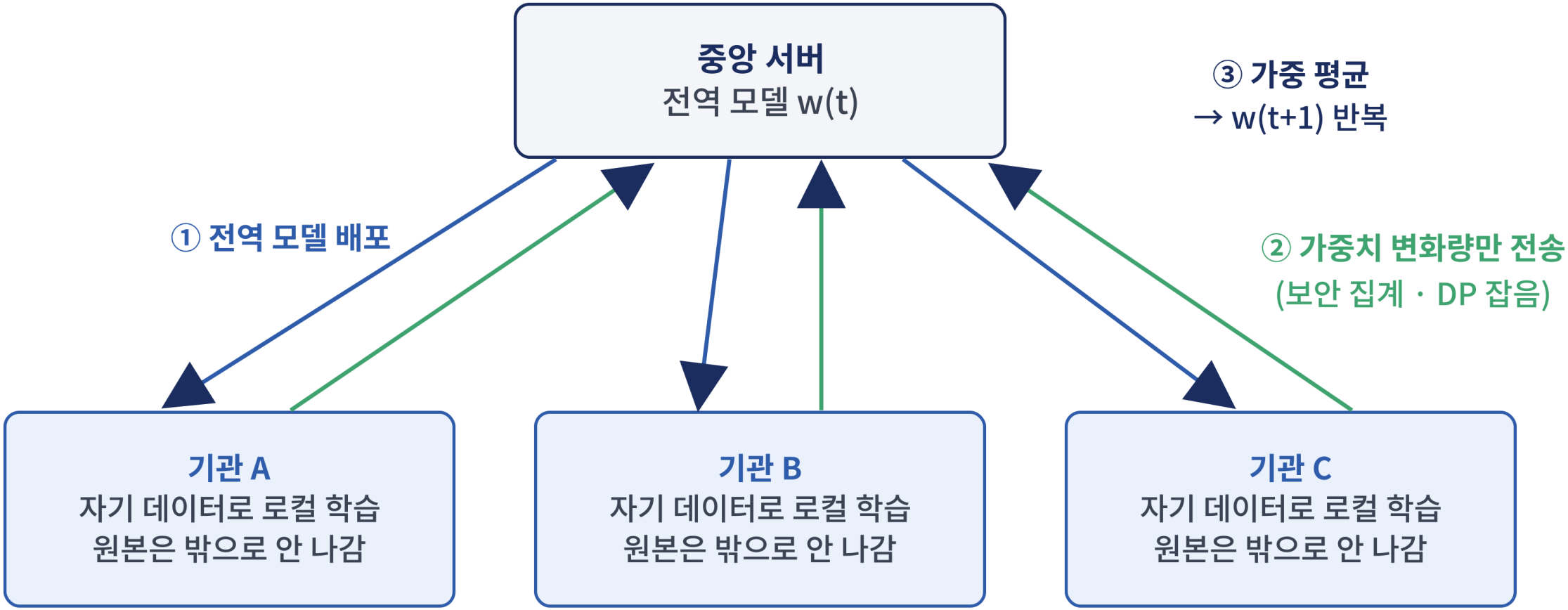
- 시험 문제(데이터)는 학교 밖으로 내보내지 않는다
- 각 학교가 만든 요약 노트(모델 업데이트)만 모아 합친다

가중 평균의 의미

- 데이터가 많은 기관의 학습 결과를 더 크게 반영한다
- 서버는 원본을 한 번도 보지 않고 전역 모델을 만든다

연합학습 한 라운드는 배포·로컬 학습·집계로 이루어진다

이 라운드를 수백~수천 번 반복해 전역 모델이 수렴한다



FedAvg는 FedSGD보다 통신 횟수를 크게 줄인다

FedSGD는 매 걸음 기울기를, FedAvg는 여러 걸음 뒤 가중치를 보낸다

$$w \leftarrow w - \underbrace{\eta}_{\text{학습률}} \cdot \frac{1}{K} \sum_{k=1}^{K} \underbrace{\nabla L(w; D_k)}_{\text{기관 } k\text{의 그래디언트}}$$

구분	FedSGD	FedAvg
기관이 보내는 것	한 번 계산한 그래디언트	여러 번 학습한 가중치
통신 횟수	학습 걸음마다	라운드당 한 번
약점	네트워크 비용이 크다	데이터 분포 차이(Non-IID)에 흔들린다

참여 기관의 데이터가 다르면 전역 모델이 흔들린다

FedProx(Li 외 2020)는 로컬 모델이 전역 모델에서 멀어지지 않게 묶는다

$$\min_{w} \quad \underbrace{F_k(w)}_{\text{기관 } k\text{의 손실}} \quad + \quad \underbrace{\frac{\mu}{2}\|w - w^t\|^2}_{\text{전역 모델에서 멀어지는 데 대한 벌점}}$$

Non-IID 문제

- 소아과와 노인의학과처럼 기관마다 데이터 분포가 다르다
- 각자 자기 방향으로 학습해 평균이 어느 쪽에도 맞지 않는다

수평 대 수직 연합학습

- 수평: 은행끼리처럼 같은 항목, 다른 고객
- 수직: 은행·통신사·쇼핑몰처럼 같은 고객, 다른 항목

연합학습은 이미 대규모 운영 단계에 들어섰다

구글 키보드(소비자 기기)와 FeTS 뇌종양 연구(병원 간 협력)

구글 Gboard (Xu 외, ACL 2023)

- 다음 단어 예측 모델을 휴대폰에서 연합학습한다
- 충전 중·Wi-Fi 연결 시에만 학습에 참여한다
- DP-FTRL과 보안 집계를 결합했다
- 이후 출시하는 신경망 언어모델은 모두 DP 보장을 요구한다

FeTS 뇌종양 (Nature Comm. 2022)

- 6개 대륙 71개 기관, 환자 6,314명의 MRI
- 서울아산병원도 참여 기관에 포함됐다
- 공개 데이터 모델 대비 수술 대상 종양 경계 33% 개선
- 전체 종양 범위는 23% 개선했다

인터넷은행 3사는 보이스피싱 모델을 함께 학습했다

금융보안원과 카카오뱅크·케이뱅크·토스뱅크의 연합학습 공동모델 — 2026년 7월부터 FDS에 적용

최대 205%

기존 은행별 모델 대비
탐지 정밀도 향상

3사 → 확대

상호금융·저축은행·우정사업본부로
기술 공유 협약(2025.12)

CIKM·NeurIPS

관련 연구가 2025년
두 학회에 채택

다른 은행의 단서를 빌린다

- 개설이 오래된 위장 계좌를 기존 모델은 정상으로 보았다
- 다른 은행이 쓰던 12시간 내 입금 합계를 함께 보자 잡혔다

왜 공동 대응인가

- 사기범은 한 곳이 막히면 보안이 약한 곳으로 옮겨 간다
- 공동모델은 이 풍선효과를 줄인다

연합학습만으로는 개인정보가 완전히 보호되지 않는다

Zhu 외(2019) Deep Leakage from Gradients 이후 역추론 공격이 이어졌다

서버가 받은 그래디언트만으로 학습에 쓰인 이미지를 거의 그대로 복원할 수 있다

공격 원리

- 가짜 입력을 놓고 그 기울기가 실제 기울기와 같아지도록 반복 수정한다
- 기울기가 일치하는 순간 가짜 입력이 원본과 닮아 있다

보강 수단

- 차등 프라이버시: 기울기에 잡음을 더한다 (PART 3)
- 보안 집계·동형암호: 서버가 개별 기울기를 못 보게 한다 (PART 4)

03

PART 3 · 차등 프라이버시

차등 프라이버시 (Differential Privacy)

한 사람이 데이터에 있든 없든 결과가 거의 같게 만든다

차등 프라이버시는 한 사람의 영향력을 수학적으로 제한한다

Dwork 외(2006). ε(엡실론)은 프라이버시 손실 예산이다

$$\Pr\left[M(D) \in S\right] \leq e^{\varepsilon} \cdot \Pr\left[M(D') \in S\right]$$

$D,\ D'$

한 사람만 다른 두 데이터

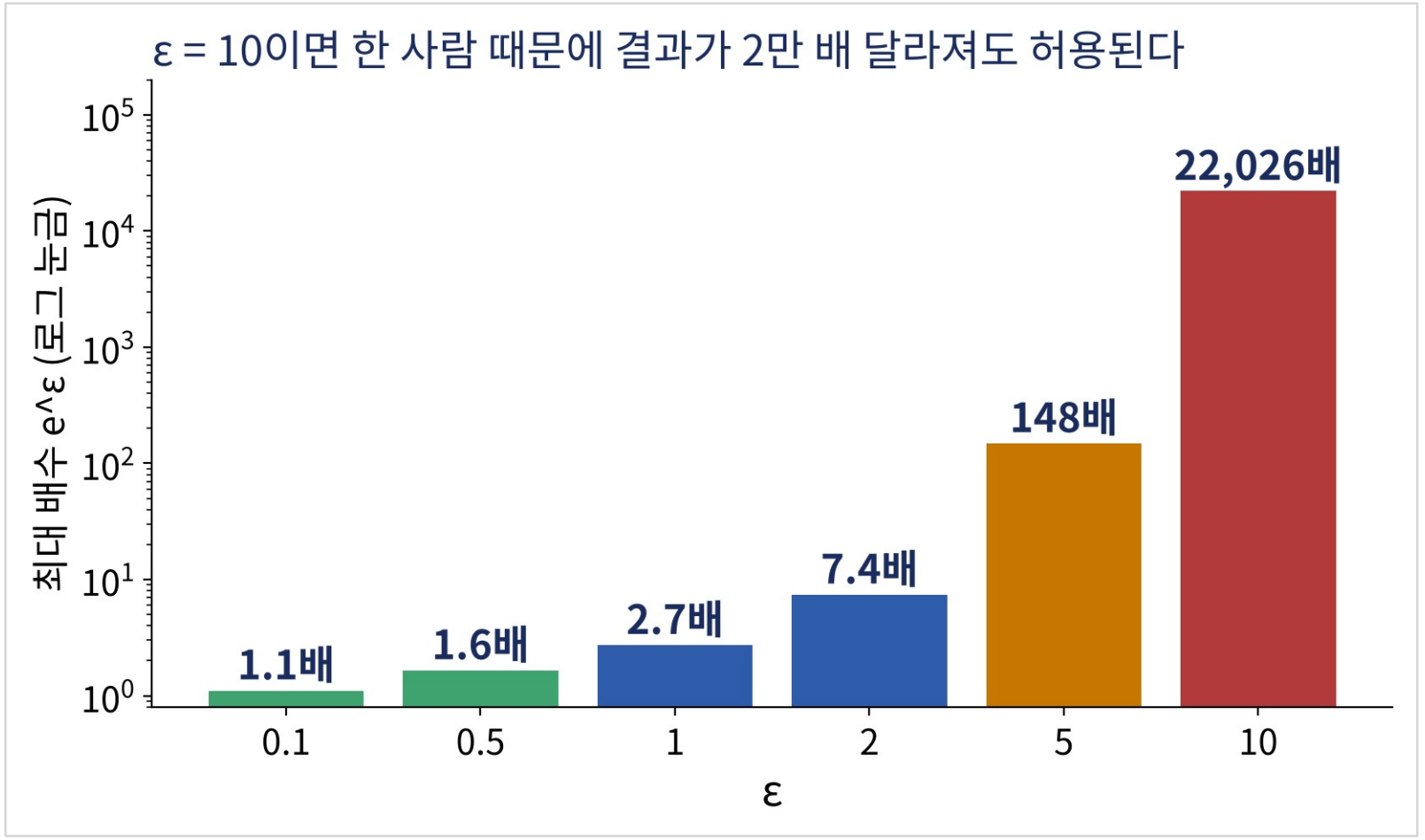
ε 값	의미	금융 데이터에서 보이는 것
0.1	매우 강한 보호	개별 고객은 전혀 식별되지 않는다
1	적당한 보호	연령대·지역 단위 패턴 정도가 드러난다
10	약한 보호	개인 특성이 상당히 노출된다

ε는 한 사람 때문에 결과가 달라질 수 있는 배수의 로그다

e^ε배: 내가 데이터에 있을 때와 없을 때 같은 결과가 나올 확률의 최대 비

읽는 법

- ε 0.1 → 1.1배
- ε 1 → 2.7배
- ε 10 → 2만 배



동전 던지기 설문은 가장 오래된 DP 메커니즘이다

Warner(1965) 무작위 응답 — 민감한 질문의 응답률을 추정한다

$$\Pr[\text{예}] = \tfrac{1}{2}\pi + \tfrac{1}{4} \quad \Longrightarrow \quad \hat{\pi} = 2\hat{p} - \tfrac{1}{2}, \qquad \varepsilon = \ln 3 \approx 1.1$$

절차

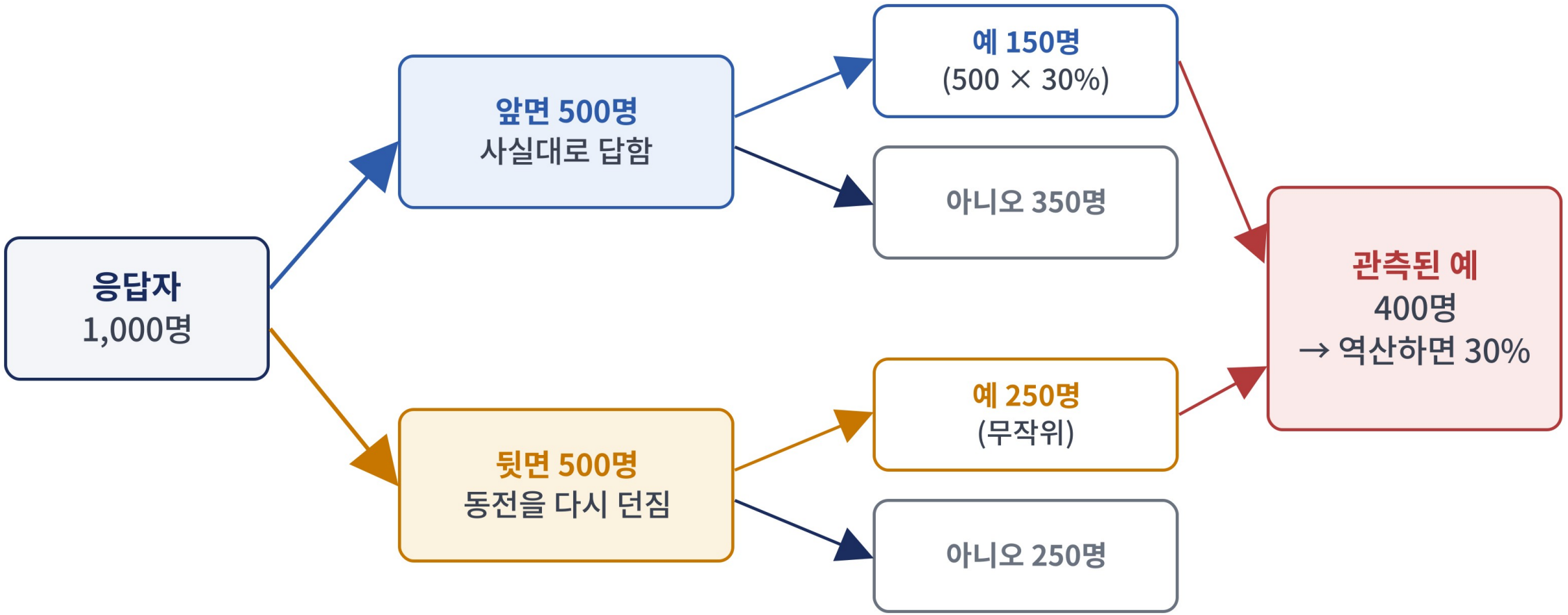
- 동전 앞면이면 사실대로 답한다
- 뒷면이면 동전을 한 번 더 던져 예·아니오를 정한다
- 조사자는 개인의 답이 진짜인지 모른다

그래도 통계는 남는다

- 예 응답 비율 p에서 실제 비율 π를 거꾸로 계산한다
- 개인은 부인할 수 있고 집단 비율은 정확해진다

1,000명 중 실제 30%라면 예라는 답은 400개가 나온다

조사자는 400개 중 누가 진짜 예인지 모르지만, 400에서 30%를 거꾸로 계산한다 (워크북 W2)



잡음 크기는 민감도를 예산으로 나눈 값으로 정한다

민감도 Δf: 한 사람이 바뀔 때 질의 결과가 최대로 변하는 폭

$$M(D) = \underbrace{f(D)}_{\text{참값}} + \text{Lap}\left(\underbrace{\frac{\Delta f}{\varepsilon}}_{\text{잡음 크기 = 민감도/예산}} \right)$$

개수 질의의 예

- 한 사람은 개수를 최대 1명 바꾸므로 Δf = 1이다
- ε = 0.5면 잡음 크기 b = 2명이다

평균 질의의 예

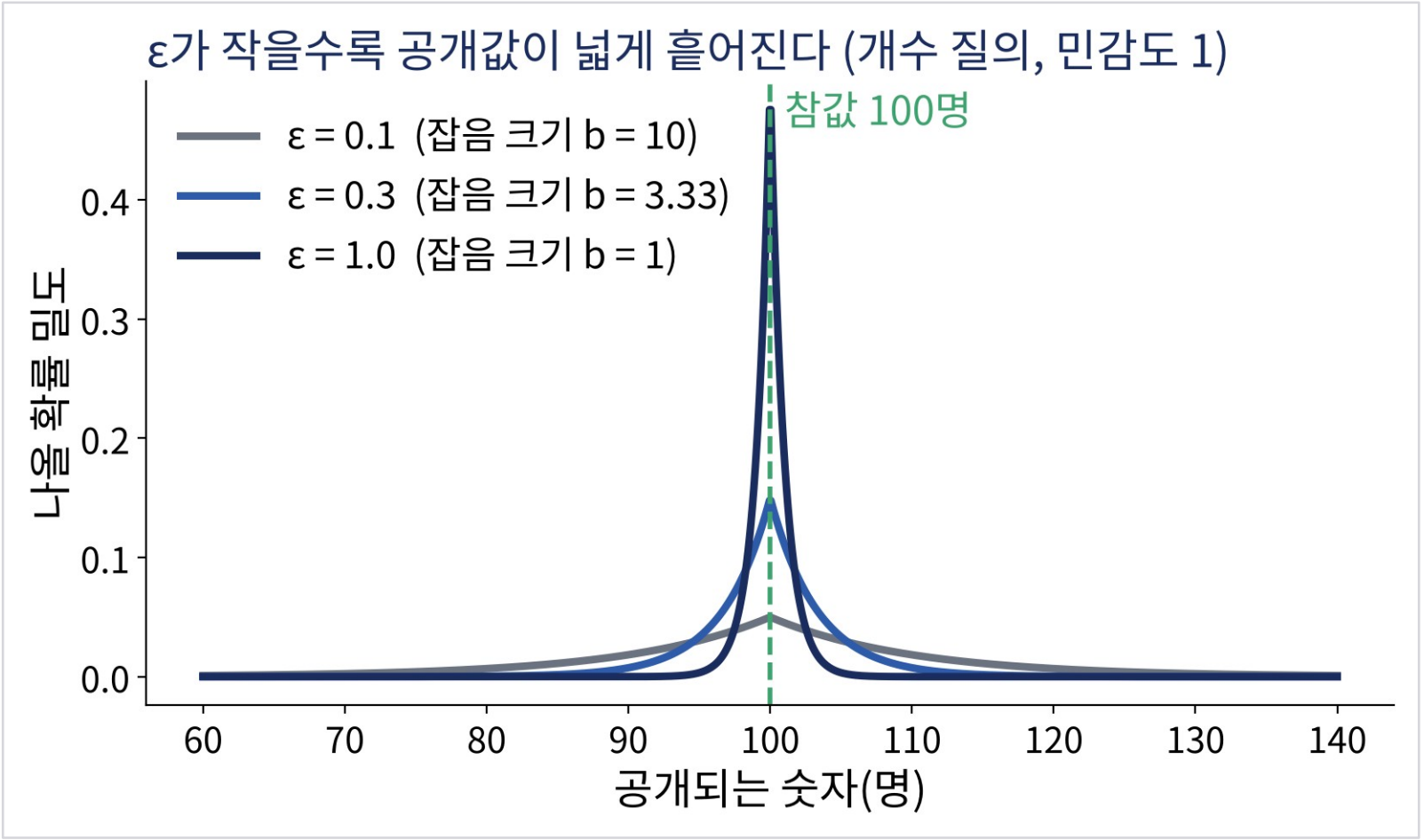
- 연봉처럼 범위가 넓으면 민감도가 커진다
- 그래서 값의 상한을 먼저 잘라(clipping) 민감도를 묶는다

ε가 작을수록 공개값이 참값에서 멀리 흩어진다

참값 100명인 개수 질의에 라플라스 잡음을 더한 공개값의 분포

읽는 법

- ε=1: 86%가 ±2명 안
- ε=0.1: 86%가 ±20명 안
- 보호와 정확도를 맞바꾼다



DP-SGD는 개인별 기울기를 자르고 잡음을 더한다

Abadi 외(2016). 질의·학습을 반복할수록 예산은 누적된다

$$\tilde{g} = \frac{1}{B}\Big(\sum_{i=1}^{B} \underbrace{\mathrm{clip}(g_i, C)}_{\text{개인별 기울기 자르기}} + \underbrace{\mathcal{N}(0, \sigma^2 C^2 I)}_{\text{가우스 잡음}}\Big)$$

$$\varepsilon_{\text{전체}} \leq \sum_{j=1}^{m} \varepsilon_j \qquad \text{(질의를 할 때마다 예산이 줄어든다)}$$

왜 두 단계인가

- 자르기로 한 사람의 영향 상한을 정하고, 그 상한에 맞춘 잡음으로 흔적을 덮는다

미국 인구조사국은 2020년 센서스에 DP를 전면 적용했다

공개 통계표로 개인 기록을 복원하는 재구성 공격이 계기였다

도입 과정

- 공개 통계표가 많으면 개인 기록을 복원할 수 있어 전통적 비식별화를 바꿨다
- 1940년 자료로 시험할 때 ε = 0.25에서 작은 지역 수치가 크게 왜곡됐다
- 2010년 자료 시연본은 총예산 4.5(인구 4.0, 주택 0.5)로 평가받았다
- 표를 하나 더 낼 때마다 예산이 줄어든다

지리 수준	예산 배분
국가	20%
주	20%
카운티	12%
센서스 트랙	12%
블록 그룹·블록	각 12%

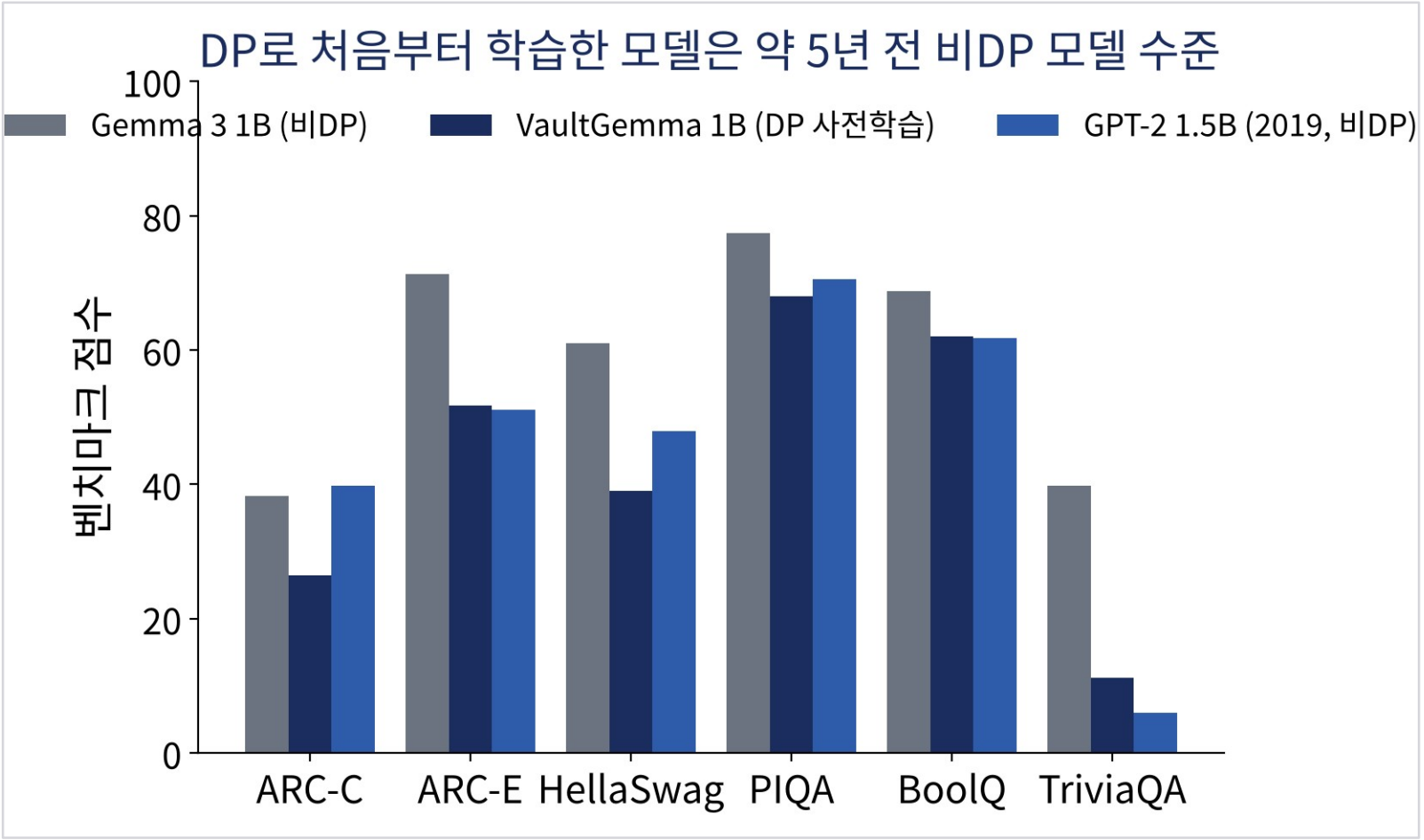
지리 수준별 배분 예시 (2020.11 인구조사국 설명자료)

구글은 처음부터 DP로 학습한 LLM을 공개했다

VaultGemma 1B(2025.9) — 10억 파라미터, Gemma 2와 같은 데이터로 전 과정 DP 사전학습

핵심 발견

- 성능은 2019년 GPT-2 수준
- 격차는 줄어드는 중
- 가중치·코드 공개



DP를 어느 단계에 거느냐에 따라 보호 범위가 달라진다

애플 사례와 VaultGemma 보고서가 주는 교훈

애플의 선택

- 2016년 iOS 10부터 이모지·입력 통계 수집에 로컬 DP를 썼다
- Apple Intelligence는 합성데이터와 DP 집계 신호로 모델을 개선한다
- 무거운 요청은 PCC로 보내되 데이터를 저장하지 않는다고 밝힌다

주의할 점

- 미세조정에만 DP를 걸면 사전학습 데이터는 보호되지 않는다
- DP는 한 번 등장한 정보를 지킨다. 여러 문서에 반복된 정보는 패턴으로 학습될 수 있다

04

PART 4 · 암호 기반 연산

동형암호와 다자간 연산

데이터를 보지 않은 채로 계산한다

동형암호는 암호문끼리 계산한 결과가 평문 계산과 같다

Gentry(2009)가 완전동형암호(FHE)의 첫 구성을 제시했다

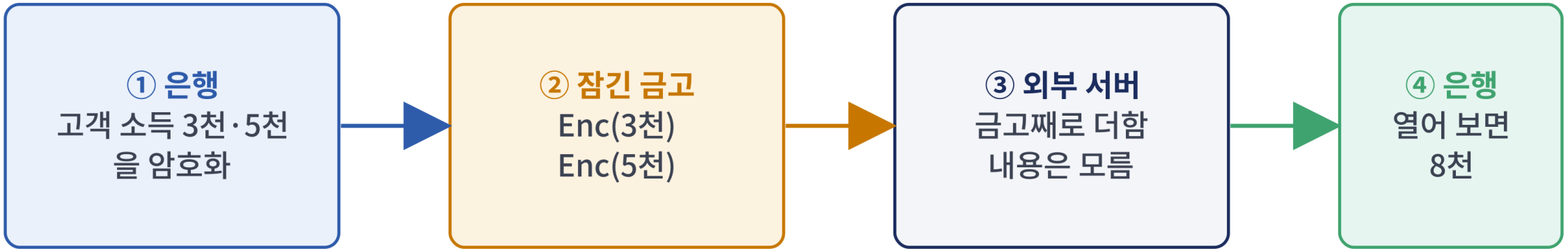
$$\mathrm{Dec}\left(\mathrm{Enc}(x_1) \oplus \mathrm{Enc}(x_2)\right) = x_1 + x_2$$

종류	가능한 연산	쓰임
부분동형(PHE)	덧셈 또는 곱셈 하나만 무제한	암호화된 합계·투표 집계
준동형(SWHE)	덧셈·곱셈을 제한된 횟수만	짧은 통계 계산
완전동형(FHE)	임의의 계산 (부트스트래핑 필요)	암호문 위의 모델 추론

비유: 잠긴 금고째로 돈을 합친다. 서버는 금고 속을 모르고, 열쇠 주인만 합계를 본다

외부 서버는 금고를 열지 않고 두 소득의 합을 구한다

신용평가를 외부에 맡기면서 고객 소득을 보여 주지 않는 구조



서버는 숫자를 한 번도 보지 않고 합계를 계산했다

동형암호는 좁은 비공개 조회에서 먼저 상용화됐다

2025~2026년 실제 배포 사례와 남은 한계

배포 사례

- 애플 Live Caller ID: 번호를 암호화한 채 스팸 DB를 조회한다
- 애플 Enhanced Visual Search: 사진 랜드마크를 암호화해 조회한다
- Zama: 2025년 6월 FHE 기업 첫 유니콘이 됐다
- 국내 크립토랩은 동형암호 분석 솔루션을 금융권에 제공한다

남은 한계

- 배포 사례의 공통점은 작은 질의 하나를 큰 DB에 묻는 형태다
- 범용 모델 학습은 평문보다 수백 배 이상 느려 아직 어렵다
- 애플은 기본 설정으로 켜서 2025년 1월 동의 논란을 겪었다

다자간 연산은 비밀을 조각내 나눠 가진 채 함께 계산한다

비밀 분산(secret sharing): 조각 하나로는 원래 값을 알 수 없다

$$x = (s_1 + s_2 + s_3) \bmod q, \qquad \sum_i x_i = \left(\sum_j \underbrace{T_j}_{\text{서버 } j\text{가 더한 조각의 합}} \right) \bmod q$$

비유: 연봉 평균 구하기

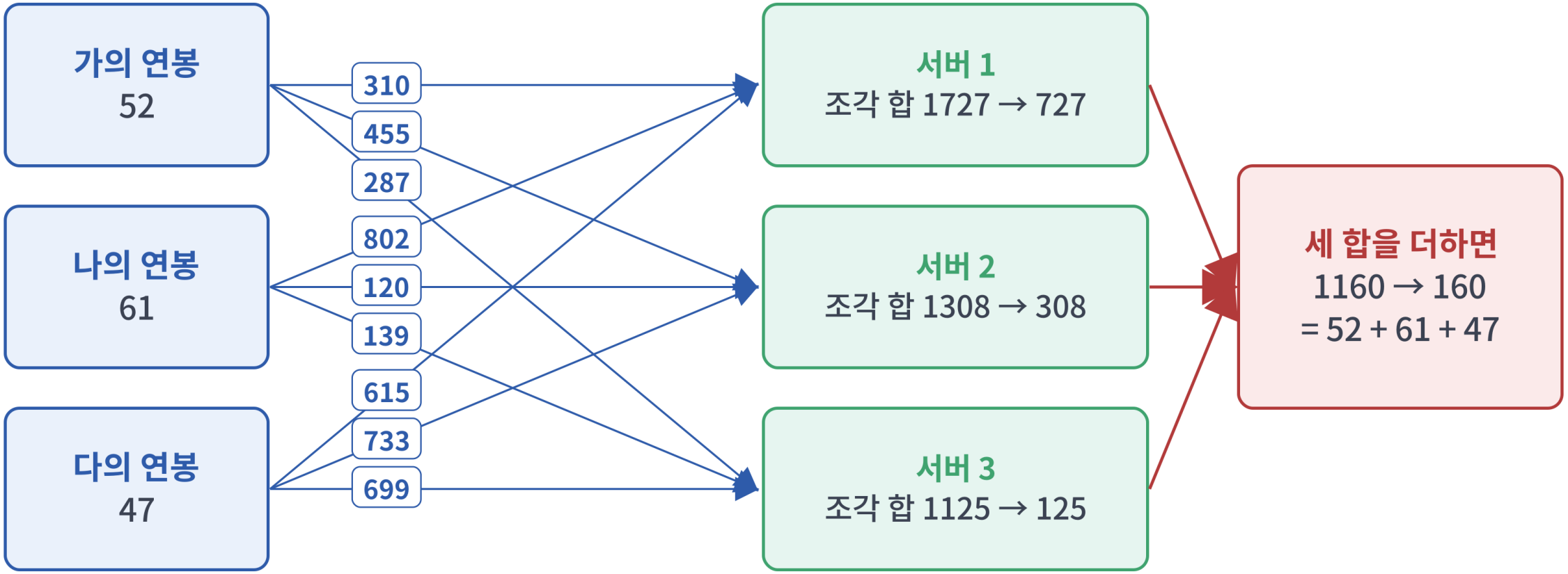
- 각자 연봉을 세 조각으로 나눠 세 서버에 보낸다
- 서버는 받은 조각만 더해 공개하고, 그 합을 다시 더하면 총액이 나온다

연합학습 속 다자간 연산

- 보안 집계(Bonawitz 외 2017)가 대표적이다
- 서버는 업데이트 합계만 알고 개별 기관 값은 모른다

세 서버는 조각만 보고도 연봉 총합 160을 맞춘다

각 조각은 무작위 숫자처럼 보인다. 조각 합을 1,000으로 나눈 나머지만 남긴다 (워크북 W7)



네 기술은 보호하는 대상과 대가가 서로 다르다

실무에서는 장단점을 보고 둘 이상을 조합한다

구분	연합학습	차등 프라이버시	동형암호	다자간 연산
보호 대상	원본 데이터의 이동	한 개인의 영향력	연산 중인 데이터	참여자 각자의 입력
비유	요약 노트만 공유	설문 속 동전	잠긴 금고 계산	퍼즐 조각
대가	통신비가 들고 Non-IID에 약하다	정확도가 떨어진다	연산이 매우 느리다	통신량이 많고 동기화가 필요하다
적합	기관·기기가 많을 때	대규모 통계와 학습	소수 기관 간 조회	중간 규모 공동 계산

05

PART 5 · 데이터·모델 단계

합성데이터와 머신 언러닝

학습 전에는 가짜를 만들고, 학습 후에는 지운다

합성데이터는 원본을 배워 존재하지 않는 기록을 만든다

만드는 방법은 크게 세 갈래이고, 평가는 세 가지 질문으로 한다

통계 모형

가우시안 코퓰라 등

변수별 분포와 변수 간 상관을 따로 배워 다시 뽑는다

표 형식 고객 데이터

딥러닝 생성 모델

GAN · VAE · 확산 모델

진짜와 가짜를 가리는 경쟁으로 복잡한 패턴을 배운다

의료 영상, 금융 시계열

시뮬레이터 · LLM

규칙 + 행위자 + 언어모델

가상 고객과 범죄자를 움직여 거래·문장을 만든다

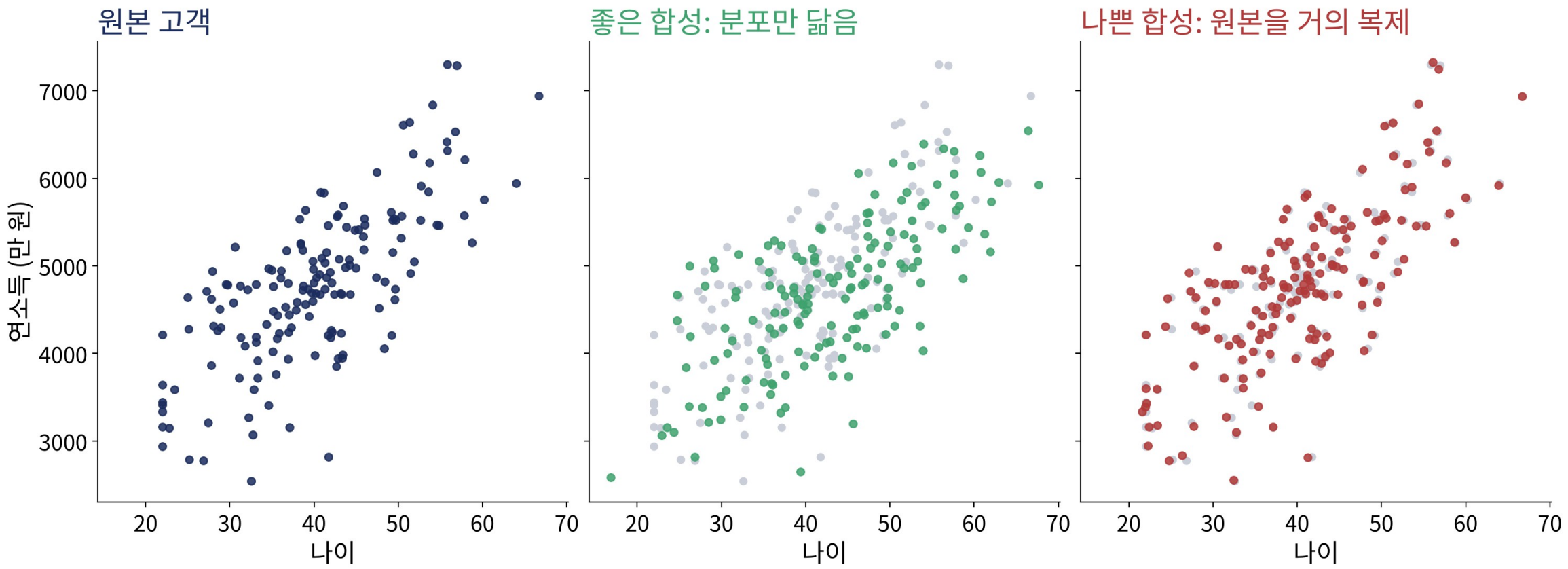
자금세탁, 자율주행

평가할 때 묻는 세 질문

- 분포가 원본과 같은가? 그 데이터로 만든 모델이 잘 작동하는가? 원본 기록과 너무 가깝지는 않은가?

좋은 합성은 분포를 닮고, 나쁜 합성은 사람을 닮는다

회색 점은 원본 고객, 색 점은 합성 고객 — 가상 고객 160명으로 그린 예시



합성데이터는 다섯 단계 검증을 거쳐야 안전하게 쓸 수 있다

개인정보보호위원회 합성데이터 생성·활용 안내서(2024.12)

① 사전 준비

목적을 정하고
원본을 전처리한다

② 생성

통계·GAN 등으로
분포를 학습해
만든다

③ 검증

안전성과 유용성을
지표로 잰다

④ 심의

심의위원회가
재식별 위험을
평가한다

⑤ 관리

활용 범위를 지키고
이력을 남긴다

핵심

- 일반 공개용 합성데이터는 안전성 중심으로 검증하고 심의를 거쳐야 익명정보로 쓸 수 있다

합성데이터도 원본을 지나치게 닮으면 개인정보가 된다

2025년 보건의료·공공안전·유통·금융 등 분야별 참조모델 5종이 공개됐다

장점: 가상 고객

- 실제 고객: 35세, 연소득 5,000만 원, 월 카드 200만 원
- 합성 고객: 33세, 4,800만 원, 190만 원 — 존재하지 않는 사람
- 패턴은 같아 모델 개발·외부 공유에 쓸 수 있다

주의: 생성 모델도 기억한다

- 희귀한 원본 레코드를 거의 복제할 수 있다
- 가장 가까운 원본과의 거리 등으로 안전성을 확인한다
- DP를 걸어 생성하면 보장이 수학적으로 남는다

합성데이터는 진짜로는 모을 수 없는 장면을 만든다

자율주행·은행·자금세탁·스마트폰에서 쓰이는 방식

Waymo 시뮬레이션 (2019)

- 가상 도로에서 100억 마일을 달렸다. 실제 도로 주행의 약 천 배다
- 드물고 위험한 장면을 바꿔 가며 수없이 반복한다

JP모건 AI 리서치

- 자금세탁·고객 여정·사기 결제·주문장 등 합성 데이터셋 6종을 공개했다
- 실데이터를 외부와 공유하지 못하는 연구 장벽을 넘는다

IBM AMLworld (NeurIPS 2023)

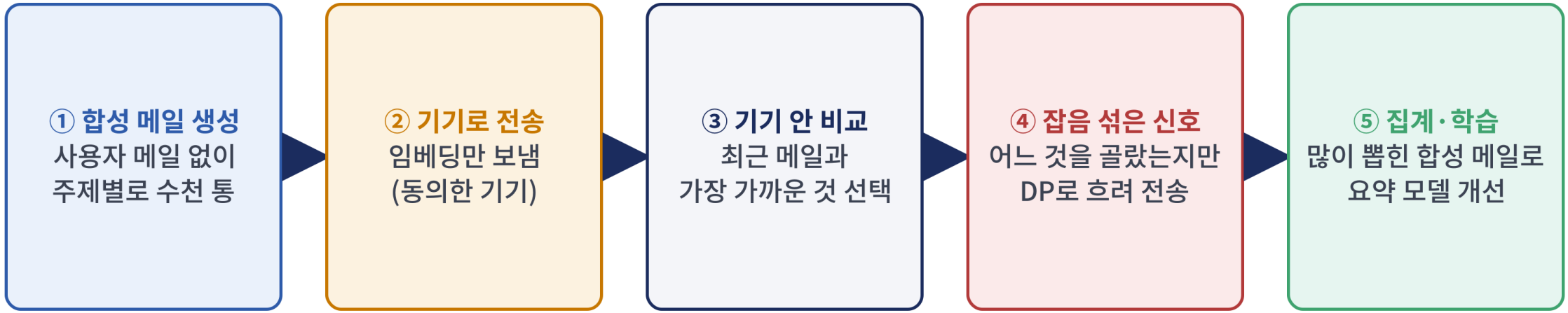
- 실제 자금세탁은 정답 라벨이 드물고 불완전하다
- 범죄 행위까지 시뮬레이션해 모든 거래에 정답을 붙였다

애플 합성 메일 (2025)

- 사용자 메일을 보지 않고 합성 메일과 DP 신호만으로 요약 기능을 개선한다
- Genmoji 인기 문구도 수백 명이 써야 보이게 잡음을 맞췄다

애플은 합성 메일 중 진짜와 닮은 것만 기기에 묻는다

Apple Machine Learning Research(2025.4) — 합성데이터와 DP를 결합한 학습 데이터 선별



실제 메일 내용은 기기를 떠나지 않는다. 애플이 아는 것은 합성 메일의 인기 순위뿐이다

국내에서도 금융·의료 합성데이터가 공공 자산으로 쌓이고 있다

개인정보위 참조모델과 금융결제원 이상거래 합성데이터 사업

개인정보위 합성데이터 참조모델

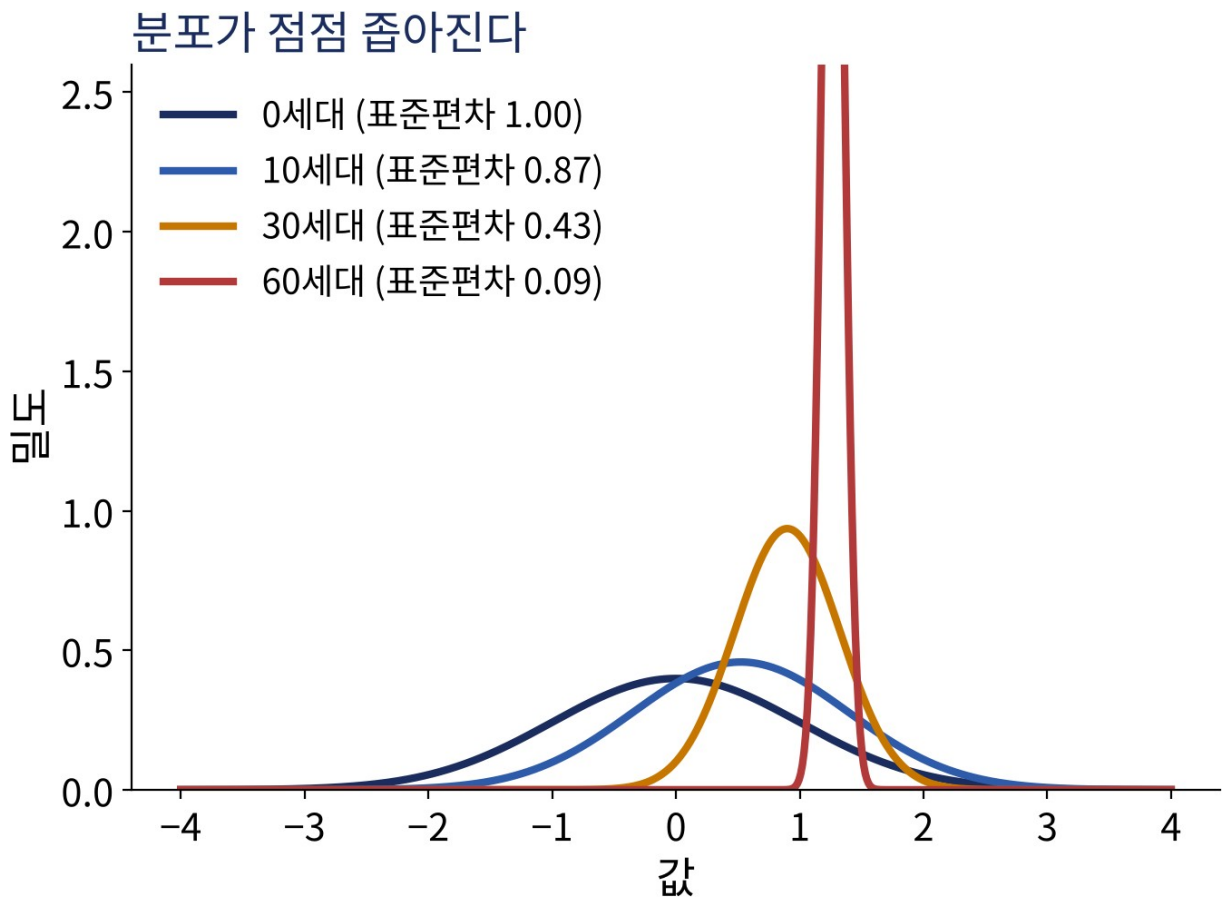
- 2024년 5월 구강 이미지 등 5종을 공개했다. 구강 이미지는 GAN으로 만들었다
- 2025년 보건의료·공공안전·유통·금융 분야 5종을 추가했다
- 가명정보 지원 플랫폼에서 누구나 내려받을 수 있다

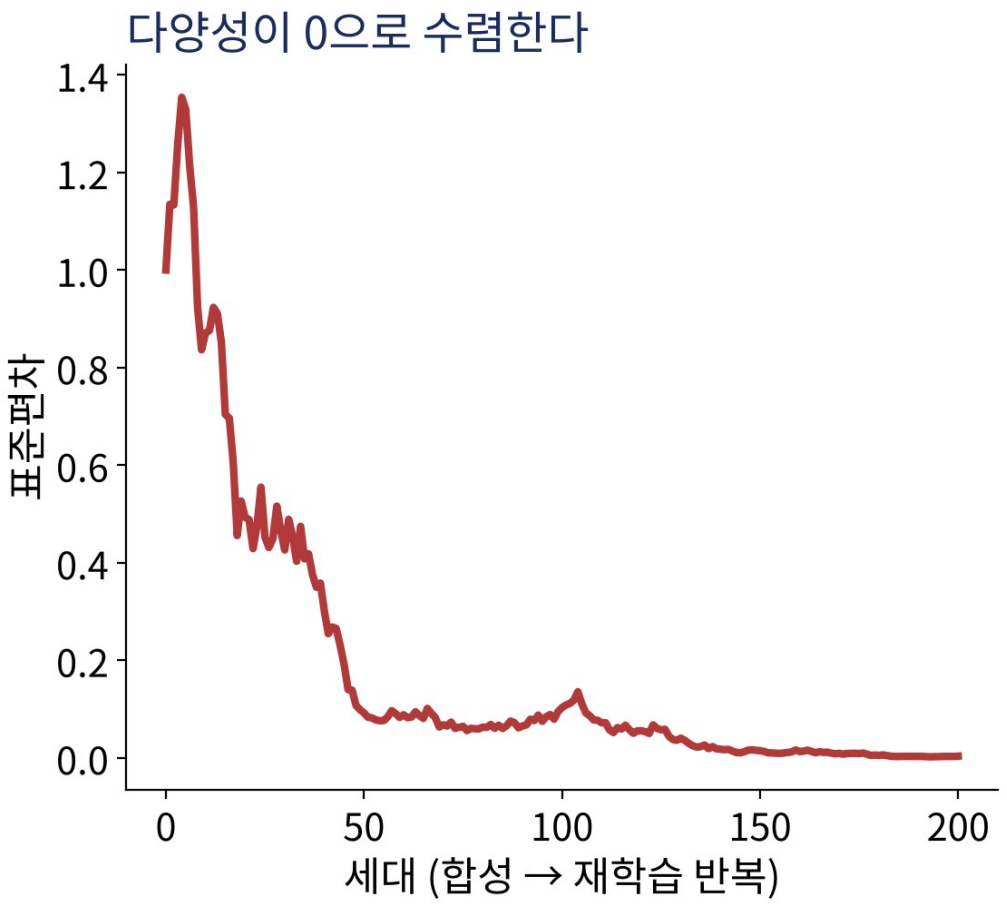
금융결제원 · 오브젠 (2025)

- 계좌이체·카드·대출 시나리오로 이상거래 합성데이터를 만든다
- 목표는 50만 건 이상이며 2025년 12월까지 구축한다
- AI Hub 공개 데이터 915종 가운데 유일한 금융 합성데이터라고 밝혔다

합성데이터로만 반복 학습하면 드문 사례부터 사라진다

Shumailov 외(Nature 2024) 모델 붕괴 — 그림은 표본 30개로 정규분포를 거듭 다시 맞춘 모의실험





합성데이터는 익명화의 만능열쇠가 아니다

Stadler 외(USENIX Security 2022) "Synthetic Data — Anonymisation Groundhog Day"

희귀한 고객일수록 합성데이터에 흔적이 남고, 연결 공격에 그대로 노출된다

연구 결과

- 합성데이터가 기존 익명화보다 나은 보호와 유용성의 균형을 보장하지 못했다
- 평균적인 고객은 숨었지만 이상치는 숨지 못했다

공개 전에 묻는 질문

- 가장 가까운 원본과의 거리를 재 보았는가?
- 희귀 레코드가 거의 그대로 나오지 않는가?
- 멤버십 추론 공격으로 시험해 보았는가?
- DP를 걸고 생성했는가?

잊힐 권리를 지키려면 모델에서도 데이터를 지워야 한다

가장 확실한 방법은 재학습이고, LLM은 근사 기법을 쓴다

$$\theta_{-i} = \arg\min_{\theta} \sum_{j \neq i} L(\theta;\, x_j,\, y_j)$$ (지울 사람 i를 빼고 다시 학습)

$$\min_{\theta} \; -L\left(\theta;\, D_{\text{잊을 데이터}}\right) + \lambda L\left(\theta;\, D_{\text{남길 데이터}}\right)$$

현실의 선택

- 개인정보위원장은 학습 데이터 일괄 삭제가 어렵다고 보고, 출력 필터링 후 재학습하는 방안을 논의 중이라고 밝혔다
- 지웠는지는 멤버십 추론 공격으로 다시 확인한다

06

PART 6 · 규제와 실무

규제 변화와 금융권 적용

안전장치를 증명하고 쓰는 시대

한국은 AI 학습용 개인정보 활용 범위를 단계적으로 넓혔다

개인정보보호위원회 안내서에서 법률 특례까지

시기	내용
2024.7	공개된 개인정보 처리 안내서: 정당한 이익 조항으로 공개 데이터 AI 학습 가능
2024.12	AI 프라이버시 리스크 관리모델, 합성데이터 생성·활용 안내서
2025.8	생성형 AI 개발·활용 개인정보 처리 안내서 (생애주기 4단계)
2026.7	제3차 기본계획(2027~29): 심사 통과 시 원본 영상·음성 학습 허용 방향
2026.9	AI 특례 개정법 공포(법률 제21910호), 2027.3.9 시행
2026 하반기	중대한 유출에 매출 최대 10% 과징금, 보안 투자 시 감경

AI 특례는 세 요건을 모두 갖춰야 적용된다

개정 개인정보보호법(2026.8.20 국회 통과) — 개인정보위 심의·의결을 거친다

세 요건

- 익명·가명 처리로는 AI 개발이 곤란하다
- 안전한 처리를 위한 안전장치를 마련했다
- 공익·사회적 이익을 위한 것이고 정보주체 이익 침해 우려가 현저히 낮다

목적 설정

의도된 용례와 예견 가능한 오용을 정한다

전략 수립

출처별 적법 근거를 확인한다

학습·개발

민감정보를 지우고 적대적 공격에 대비한다

적용·관리

학습 데이터 노출을 점검하고 권리를 보장한다

EU는 고위험 AI 의무 시점을 늦췄지만 내용은 그대로 두었다

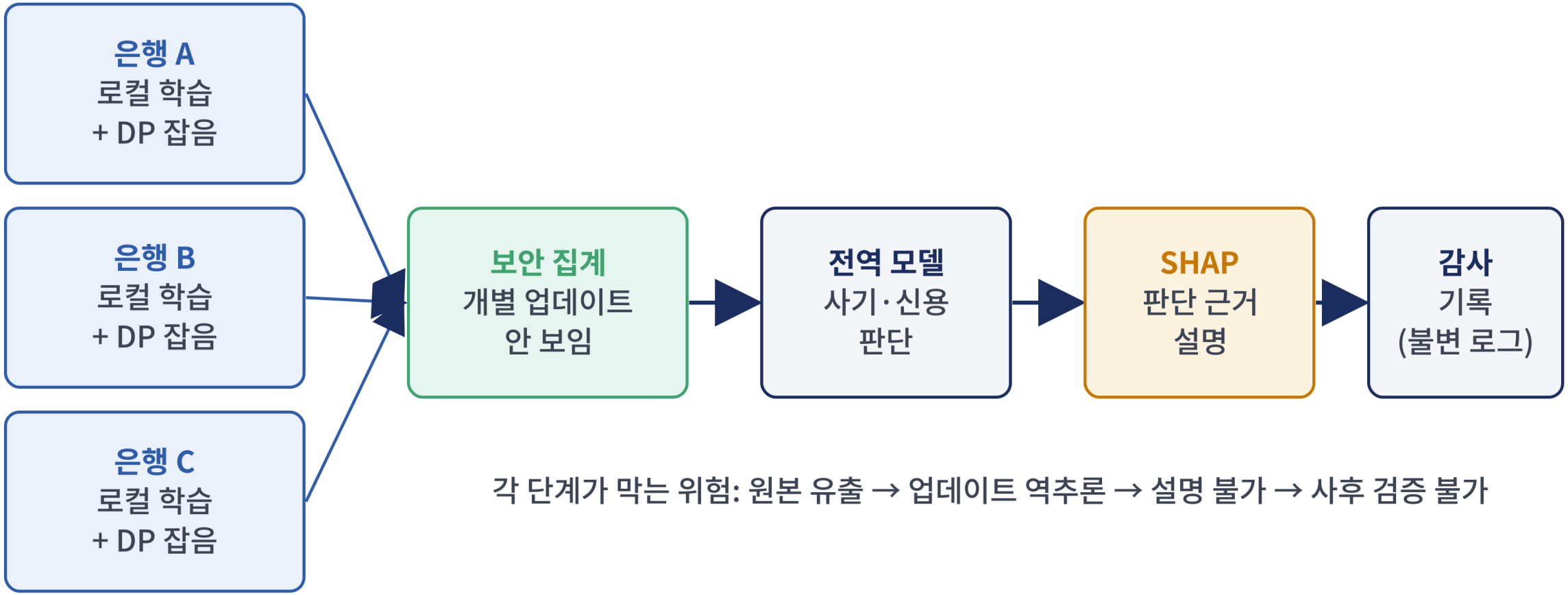
디지털 옴니버스 AI 규정(EU 2026/1744), 2026.7.27 시행

시점	내용
2025.11.19	집행위원회가 디지털 옴니버스 제안 (GDPR 정당한 이익으로 AI 학습 허용 조항 포함)
2026.8.2	범용 AI(GPAI) 의무는 연기 없이 계속 적용
2026.12.2	누디피케이션 앱·아동 성착취물 생성 금지 신설
2027.12.2	독립형 고위험 AI(부속서 III) 의무 적용
2028.8.2	제품 내장형 고위험 AI(부속서 I) 의무 적용

GDPR 제22조(자동화된 결정에 대한 권리)는 그대로다. 신용평가 AI는 설명 가능성을 함께 갖춰야 한다

금융 협업 모델은 보호·설명·감사를 한 파이프라인에 묶는다

연합학습 + DP + 보안 집계 + SHAP 설명 + 감사 기록을 결합한 설계 예



각 단계가 막는 위험: 원본 유출 → 업데이트 역추론 → 설명 불가 → 사후 검증 불가

업무 성격에 따라 기술 조합을 다르게 고른다

데이터가 어디 있고, 누가 무엇을 보면 안 되는지부터 따진다

업무	권장 조합	이유
기관 간 사기 탐지	연합학습 + 보안 집계	데이터 이동 없이 패턴을 공유한다
신용평가 공동 개발	연합학습 + DP	개인 기여가 모델에 남지 않게 한다
민감정보 외부 조회	동형암호	상대가 질의 내용을 보지 못한다
규제 보고·통계 공개	차등 프라이버시	공개 통계의 재구성을 막는다
외부 위탁 모델 개발	합성데이터 (+ DP)	원본을 넘기지 않는다

기술만으로는 부족하고 책임 체계가 함께 있어야 한다

개인정보위 생성형 AI 안내서와 금융보안원 AI 보안성 검증

CPO 중심 거버넌스

- CPO가 AI 전 과정의 적법성과 안전성을 관리·감독한다
- 개인정보 영향평가와 레드티밍으로 위험을 계속 평가한다
- CAIO·CISO와 협력하고 기획 단계부터 개인정보 안심설계(PbD)를 적용한다

금융 AI 보안성 검증

- 제3자가 데이터 오염·모델 오염 공격을 점검한다
- 모델 추출·모델 인버전·회피 공격도 모의 공격으로 확인한다
- 혁신금융서비스 지정 생성형 AI는 망분리 예외 구간 보안대책을 평가받는다

다음 상황에서 무엇을 판단해야 하는가

정답보다 판단 근거를 설명하는 데 집중한다

Q1	은행 세 곳이 사기 탐지 공동모델을 만든다. 연합학습만으로 충분한가, 무엇을 더해야 하는가?	**기술 조합**
Q2	ε를 1에서 8로 올리자 정확도가 크게 올랐다. 무엇을 잃었고, 누가 이 결정을 내려야 하는가?	**프라이버시 예산**
Q3	고객이 삭제를 요구했는데 재학습에 3주가 걸린다. 그동안 어떤 조치를 할 것인가?	**잊힐 권리**
Q4	고객 데이터에서 이름만 지우고 나이·동·성별은 남겨 외부에 주려 한다. 무엇이 문제인가?	**재식별**

PPML은 데이터 활용과 신뢰를 함께 얻는 방법이다

세 메시지를 다시 정리한다

1

기억을 막아야 보호가 완성된다

원본을 지키는 연합학습에 DP와 보안 집계를 더해야 역추론과 추출을 막는다.

2

보호와 정확도는 예산으로 맞바꾼다

ε를 정하는 일은 기술 결정이 아니라 위험 수용 수준을 정하는 경영 결정이다.

3

증명할 수 있는 안전장치가 경쟁력이다

AI 특례·안내서·EU 규정 모두 문서화된 안전조치를 요구한다.

다음 단계 — 워크북에서 FedAvg·무작위 응답·라플라스 잡음·비밀 분산을 손으로 계산한다

재식별·합성데이터 출처

PART 1과 PART 5 보강 사례의 근거

주제	출처
우편번호·생년월일·성별, 웰드 주지사	Sweeney(2000, 2002); Data re-identification 문헌 정리
넷플릭스·AOL·뉴욕 택시	Narayanan·Shmatikov(2008); NYT(2006); Tockar(2014)
결제·위치·인구통계	de Montjoye 외(Science 2015, Sci. Rep. 2013); Rocher 외(Nat. Comm. 2019)
합성데이터 사례	Waymo(2019); JP모건 AI 리서치; Altman 외(NeurIPS 2023); Apple MLR(2025)
합성데이터 위험	Shumailov 외(Nature 2024); Stadler 외(USENIX Security 2022)
국내 합성데이터	개인정보위 참조모델(2024~25); 파이낸스스코프(2025.7.9)

주요 출처

본문 수치와 사례의 근거

주제	출처
FedAvg·Gboard	McMahan 외(2017) AISTATS; Xu 외(2023) ACL Industry
FeTS 뇌종양	Pati 외(2022) Nature Communications 13:7346
국내 보이스피싱 공동모델	금융보안원 발표(2026.6.24), 바이라인네트워크·연합뉴스 보도
학습 데이터 추출	Nasr 외(2025) ICLR; 그래디언트 역추론: Zhu 외(2019) NeurIPS
DP·센서스·VaultGemma	Dwork 외(2006); 미 인구조사국 자료; VaultGemma 기술보고서(2025)
한국·EU 규제	개인정보위 안내서(2024~25), 개정 보호법(2026), EU 2026/1744